

Zscaler Endpoint DLP Assessment (Windows)

Date: 09-04-2026

Table of Contents

DISCLAIMER	3
DOCUMENT DETAILS	3
AUTHORS & REVIEWERS	3
VERSIONS	3
EXECUTIVE SUMMARY	4
Objectives	4
Scope	4
Caveat	4
Summary	4
Findings Summary	4
Recommendations	5
FINDINGS SUMMARY	6
FINDINGS	7
Sensitive Data Exfiltration Over Encrypted Channels	7
Sensitive Data Exfiltration via Clipboard	8
DLP Bypass via Document Classification Stripping	9
Sensitive Data Exfiltration via USB Removable Media	11
Inconsistent DLP Lineage Tracking Across File Types and Exfiltration Channels	12
APPENDIX A – Test Data	15
APPENDIX B – Test Case Result Matrix	17
APPENDIX C – Exfiltration Channels	20
Unrestricted Data Transfer via USB Removable Media	20
Unauthorized Cloud Storage (Google Drive / Personal Gmail)	23
Compute Instance Transfer (SCP to AWS EC2)	25
Cloud Storage Bucket (AWS S3)	27
Internal Network Share (SMB) Transfer	28
Personal AI Assistant Session Data Exfiltration	29
Personal GitHub Repository and Code Spaces Data Exfiltration	32
RATINGS GUIDE	34

DISCLAIMER

This material is confidential, and unpublished property of Fair Isaac Corporation (FICO). Receipt or possession of this material does not convey rights to divulge, reproduce, use, or allow others to use it without the specific written authorization of FICO and use must conform strictly to the license agreement.

The information in this document is subject to change without notice. If you find any problems in this documentation, please report them to us in writing. Neither FICO nor its affiliates warrant that this documentation is error-free, and changes may need to be made periodically.

DOCUMENT DETAILS

Description	This document contains information about the testing carried out by the offensive Security team, their potential impact on FICO, and our strategies to address them.
Purpose	Zscaler Endpoint DLP Assessment (Windows)
Conducted By:	FICO Ethical Hacking Team
Document Proprietary	FICO
Date	9-April-2026
Distributed To:	Qasim Ali - Cyber Security-Vice President Gema Landaverde - Cyber Security-Director Bradley Thomas - Cyber Security-Director Deepak Puthalath - Cyber Security-Director Christopher Swindull - Cyber Security-Sr Director Sasank Maddala - Cyber Security-Sr Director

AUTHORS & REVIEWERS

Name	Role
Devanshu Nagpal	Assessment Lead
Bojan Ristic	Technical Reviewer
Gema Landaverde	Approval

VERSIONS

Version	Updated on	Author	Changes
1.0	09-April-2026	Devanshu Nagpal	Initial Draft
1.1	10-April-2026	Bojan Ristic	Changes & formatting throughout. Comments also added to be addressed
1.2	13-April-2026	Devanshu Nagpal	Comments Addressed

EXECUTIVE SUMMARY

The FICO Red Team conducted an assessment on endpoint Data Loss Prevention (eDLP) implementation in Zscaler managed Windows endpoints. The assessment simulated real-world insider threat and data exfiltration scenarios across multiple channels using a structured test data spanning all FICO classification categories. The objective was to determine whether the current DLP implementation can effectively detect, alert on, and prevent sensitive data from leaving managed endpoints through common and emerging exfiltration methods.

Objectives

- Assess the implementation of the Zscaler Endpoint DLP solution on Windows endpoints
- Determine whether the DLP solution can be disabled or tampered with.
- Identify what data and activity the solution monitors.
- Evaluate what data classifications and categories are prevented from being exfiltrated.
- Determine whether the solution can be bypassed to exfiltrate sensitive or classified data.

Scope

Managed Windows endpoints with the Zscaler DLP agent active. A structured test data corpus spanning multiple classification categories was used throughout testing. Refer to [Appendix A](#) for full test data corpus and classification details.

Caveat

This assessment focused on common and accessible exfiltration techniques available to an insider threat or user with standard endpoint access. More covert exfiltration methods commonly employed by sophisticated adversaries were outside the scope of this assessment. Several such techniques have been identified and shared separately with the relevant team as part of previous Red Team Attack Path Mappings and Adversary Simulations.

Summary

The assessment identified significant gaps in the current DLP implementation across all tested exfiltration channels. While partial protection exists for Confidential and Restricted Confidential Microsoft Office files in specific formats, most sensitive data transferred successfully across every channel without blocking. Where monitoring, logging, and justification prompts were in place, these do not constitute effective controls, transfers should be blocked and validated based on data classification and content, not user self-certification. A systemic file format conversion bypass rendered Zscaler protection controls ineffective across all channels, and the absence of clipboard monitoring left copy/paste data exfiltration entirely undetected. The current DLP implementation does not provide sufficient protection against an insider threat or a compromised endpoint.

Findings Summary

A total of 5 findings were identified during this assessment rated as High. The assessment covered 7 exfiltration methods representing the most common and easily feasible techniques available to an insider threat or user with standard endpoint access. The most significant findings include Zscaler DLP lacking coverage for alternate protocols such as SCP, SSH, and git over HTTPS while defaulting to user-facing prompts rather than blocking across monitored channels, and unmonitored clipboard activity leaving AI assistant-based exfiltration entirely invisible to the DLP solution. A systemic Microsoft classification label stripping bypass via Save As was identified that rendered Restricted Confidential and Confidential protections ineffective across every exfiltration channel tested, and USB removable media access was found to be unrestricted at the device insertion level with inconsistent

protection across file formats. Additionally, DLP lineage tracking was only enforced for USB exfiltration method despite the capability existing to extend this protection universally.

Recommendations

The assessment findings point to several systemic gaps that should be addressed as a priority:

1. Extend Zscaler DLP policy to cover non-HTTP protocols including SCP, SSH, and git over HTTPS. Update enforcement policy to block rather than prompt for sensitive data transfers across all channels justification prompts should not be the sole control for sensitive or classified data and transfers should be validated based on data classification and content rather than user self-certification.
2. Implement clipboard monitoring on managed endpoints to detect and alert copy operations involving sensitive or classified data, closing the gap exploited via AI assistant sessions.
3. Restrict access to personal cloud storage, personal AI assistants, personal GitHub accounts, and consumer cloud infrastructure on managed endpoints via Zscaler policy.
4. Treat the file format conversion bypass as an immediate remediation priority. Configure Microsoft Purview to prevent saving labelled files in unsupported formats or to re-apply labels automatically where technically feasible, given its systemic impact across all exfiltration channels tested.
5. Implement label lineage tracking to detect and alert when sensitivity labels are removed or downgraded through file format conversion, manual changes, or container formats such as zip archives. Extend content and syntax-based detection to archive formats and apply consistently across all exfiltration channels, not only USB.
6. Restrict USB access by default on managed endpoints and enforce a formal approval and exception process.
7. Adopt and actively promote the corporate-approved AI assistant (chat.corp-ai.fico.com) as the sanctioned alternative to personal AI tools on managed endpoints. Block access to personal AI assistant platforms including ChatGPT and Claude at the network layer via Zscaler policy to drive adoption and eliminate the unmonitored exfiltration channel entirely.

FINDINGS SUMMARY

Severity	Finding
High	Sensitive Data Exfiltration Over Encrypted Channels
High	Sensitive Data Exfiltration via Clipboard
High	DLP Bypass via Document Classification Stripping
High	Sensitive Data Exfiltration via USB Removable Media
High	Inconsistent DLP Lineage Tracking Across File Types and Exfiltration Channels

FINDINGS

Sensitive Data Exfiltration Over Encrypted Channels

Severity: **High**

Impact: **High**

Likelihood: **Medium**

Summary:

Attackers that have compromised an endpoint can exfiltrate sensitive labelled FICO documents over encrypted protocols and bypass DLP. This could result in data loss, ransom, financial and regulatory penalties, and reputational damage for FICO.

Zscaler DLP failed to prevent exfiltration of documents marked restricted and confidential when alternate protocols such as HTTPS, SCP, and SSH were used. The following exfiltration methods were all successful:

- Exfiltration via SCP to an AWS EC2 instance
- AWS CLI transfers to S3 buckets
- Git push to personal GitHub repository

Across all tested exfiltration channels, Zscaler defaulted to prompting the user for justification rather than blocking sensitive data transfers, providing no meaningful security barrier to exfiltration.

Zscaler did detect data transfers to SMB network shares, however the response was simply a meaningless justification prompt rather than a block. The user could provide any reason and proceed with the transfer without additional challenge or verification.

The regulatory, financial and reputational impact of sensitive data potentially being exfiltrated from a compromised device is high. Likelihood of data exfiltration is medium since the device would have to be compromised first, however once compromised DLP is ineffective. Overall severity is high as a result.

Steps to Reproduce:

See the following appendices for examples of data exfiltration over encrypted channels:

- [APPENDIX C - Unauthorized Cloud Storage \(Google Drive / Personal Gmail\)](#)
- [APPENDIX C - Compute Instance Transfer \(SCP to AWS EC2\)](#)
- [APPENDIX C - Cloud Storage Bucket \(AWS S3\)](#)
- [APPENDIX C - Internal Network Share \(SMB\) Transfer](#)
- [APPENDIX C - Personal GitHub Repository and Code Spaces Data Exfiltration](#)

Remediation:

Extend Zscaler DLP policy to cover other encrypted protocols including SCP, SSH, and HTTPS. Update DLP policy to block data transfer rather than prompt for justification and allow transfers to take place – even if data is encrypted on transfer.

[Return to Findings Summary](#)

Sensitive Data Exfiltration via Clipboard

Severity: **High**

Impact: **High**

Likelihood: **Medium**

Summary:

Attackers that have compromised an endpoint can exfiltrate sensitive data over via copy/paste clipboard operations to bypass DLP. This could result in data loss, ransom, financial and regulatory penalties, and reputational damage for FICO.

The endpoint DLP solution has no visibility into clipboard activity on managed Windows endpoints. Sensitive data including credentials, source code, and classified content can be copied and pasted into any unauthorised application, browser session, or external tool without triggering any alert or block.

During testing, sensitive data was copied from classified test files and pasted directly into a personal AI assistant session without any DLP response. No clipboard monitoring is configured on managed endpoints, meaning data leaving via copy/paste operations is entirely outside the inspection scope of the current DLP implementation. Unlike file transfer-based exfiltration, clipboard-based exfiltration leaves no file movement trail and is not subject to any of the existing DLP controls. This gap is particularly significant in the context of browser-based tools, personal AI assistants, and web applications where data can be pasted and immediately shared or made public. This is applicable across all browser-based and application-level exfiltration vectors.

The regulatory, financial and reputational impact of sensitive data potentially being exfiltrated from a compromised device is high. Likelihood of data exfiltration is medium since the device would have to be compromised first, however once compromised DLP is ineffective to protect against copy/paste data exfiltration. Overall severity is high as a result.

Steps to Reproduce:

1. On a managed endpoint, open a classified or sensitive test file.
2. Select and copy sensitive content from the file to the clipboard.
3. Open any unauthorised application or browser session and paste the content.
4. Observe no DLP alert or block is triggered at any point.

Remediation:

Implement clipboard monitoring within the Zscaler DLP policy to detect copy/paste operations involving sensitive or classified content. Clipboard monitoring should be configured to alert on and block paste operations to unauthorized destinations.

[Return to Findings Summary](#)

DLP Bypass via Document Classification Stripping

Severity: **High**

Impact: **High**

Likelihood: **Medium**

Summary:

Attackers that have compromised an endpoint can bypass DLP protections based on document classification to exfiltrate sensitive data over multiple methods (shown in [Appendix C](#)). This could result in data loss, ransom, financial and regulatory penalties, and reputational damage for FICO.

A systemic bypass was identified across multiple exfiltration channels whereby saving a Restricted Confidential or Confidential file in a format that does not support Microsoft sensitivity labels strips the classification metadata entirely. The resulting files transfer without Zscaler encryption, alerting, or any DLP response across all tested exfiltration channels.

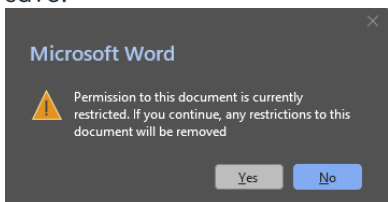
Microsoft sensitivity labels are only retained in a subset of Office-compatible file formats. When a labelled file is saved as an unsupported format, the classification metadata is stripped, and the file loses all associated DLP protections. This was confirmed effective across every exfiltration channel tested in this assessment, rendering the strongest available DLP control Restricted Confidential encryption entirely ineffective with a single Save As operation. No technical skill is required, and Microsoft Office itself facilitates the action, presenting only an optional warning that can be dismissed.

- Formats that retain protection: .docx, .xml, .dotm, .dotx, .docm, .xlsx, .xlsb, .xlsm, .xltn, .xltx
- Formats that strip classification and bypass DLP: .htm, .mht, .odt, .pdf, .rtf, .txt, .xps, .txt, .xps, .csv, .dif, .dos, .csv
- Affected classifications: FICO Restricted Confidential, FICO Confidential.
- Affected channels: USB Removable Media, Google Drive / Personal Gmail, SCP to AWS EC2, AWS S3 Bucket, SMB Network Share, External Email, GitHub Code Spaces

The regulatory, financial and reputational impact of sensitive data potentially being exfiltrated from a compromised device is high. Likelihood of data exfiltration is medium since the device would have to be compromised first, however once compromised DLP is ineffective to protect against classification stripping of sensitive documents for the purpose of data exfiltration. Overall severity is high as a result.

Steps to Reproduce:

1. Open a Restricted Confidential or Confidential file on a managed endpoint.
2. Select File > Save As and choose any format from the unprotected list above.
3. A Microsoft Office warning may appear noting the format does not support sensitivity labels, accept and save.



4. Transfer the converted file via any exfiltration channel.
5. Observe no encryption, no alert, and no blocking is applied.
6. Confirm the file is fully readable at the destination on any device including non-FICO devices.

Observe that this method was used repeatedly in exfiltration methods demonstrated in [APPENDIX C](#).

Remediation:

DLP policy should be updated to detect and block Save As operations on sensitive documents that would result in classification label stripping. Microsoft Purview or equivalent should be configured to prevent saving labelled files in formats that do not support sensitivity labels, or to re-apply the label where technically feasible. This bypass should be treated as a systemic remediation priority given its effectiveness across all tested exfiltration channels. It is recommended to implement a labelling mechanism. If labelling exists in Zscaler this should be used to track the lineage of sensitive files.

Office file types supported

Generally, Office apps that have built-in labeling for Word, Excel, and PowerPoint files support the Open XML format (such as .docx and .xlsx) but not the Microsoft Office 97-2003 format (such as .doc and .xls), Open Document Format (such as .odt and .ods), or other formats.

Note

You can prevent users from opening or saving the older file types for Word, Excel, and PowerPoint in Windows. For instructions, see [Block specific file format types in Office 2016](#).

When a file type isn't supported for sensitivity labels, the **Sensitivity** button isn't available in the Office app.

See:

- [Purview-sensitivity-labels-office-apps](#)
- [Block specific file format types in Office 2016](#)

[Return to Findings Summary](#)

Sensitive Data Exfiltration via USB Removable Media

Severity: **High**

Impact: **High**

Likelihood: **Medium**

Summary:

Attackers that have compromised an endpoint can bypass DLP protections to exfiltrate sensitive data using external USB devices. This could result in data loss, ransom, financial and regulatory penalties, and reputational damage for FICO.

USB removable media can be inserted into managed FICO endpoints without any alert, prompt, or monitoring trigger. Data across all classification categories was successfully transferred to USB with no blocking. Restricted Confidential and Confidential files in select formats were initially encrypted on transfer, but this could be bypassed via file format conversion (see [DLP Bypass via Document Classification Stripping](#)). Refer to [Appendix A](#) for full test case details and results. On a non-FICO device, Restricted Confidential and Confidential .docx/.xlsx files were unreadable, but all other formats were fully accessible.

The regulatory, financial and reputational impact of sensitive data potentially being exfiltrated from a compromised device is high. Likelihood of data exfiltration is medium since the device would have to be compromised first, however once compromised DLP is ineffective to protect data exfiltration via USB medium. Overall severity is high as a result.

Steps to Reproduce:

See [APPENDIX C - Unrestricted Data Transfer via USB Removable Media](#).

Remediation:

Zscaler DLP policy should be updated to block rather than notify for sensitive data transfers to removable media. Encryption should be enforced across all file formats, not just Confidential and Restricted Confidential classifications. Aside from DLP, a strict USB device control policy should be added to restrict or block removable media insertion altogether on managed endpoints - requiring formal business justification for approved exceptions.

[Return to Findings Summary](#)

Inconsistent DLP Lineage Tracking Across File Types and Exfiltration Channels

Severity: **High**

Impact: **High**

Likelihood: **Medium**

Summary:

Attackers that have compromised an endpoint can reliably abuse gaps in lineage tracking of files marked as sensitive to bypass DLP protections and exfiltrate them. This could result in data loss, ransom, financial and regulatory penalties, and reputational damage for FICO.

The DLP solution demonstrates inconsistent lineage tracking across file types and exfiltration channels. Source code files are detected via content and syntax analysis on USB drag and drop but bypass detection entirely when zipped. Office files maintain protection through zip, double zip, and password-protected archives on USB, demonstrating the capability exists but is not consistently applied. Source code detection does not trigger on any other exfiltration channel, indicating lineage enforcement is channel-specific rather than universal.

During USB testing, Python and Java source code files triggered DLP alerts on drag and drop even after removing classification labels, PII, shebang lines, and import statements indicating content and syntax-based detection is in place. However, zipping the same files, including FICO labels and PII intact, bypassed detection entirely with no alert triggered. This inconsistency suggests the DLP engine performs content inspection on raw files but does not inspect container formats such as zip archives for source code content.

In contrast, Microsoft Office Restricted Confidential and Confidential files-maintained protection through zip, double zip, and password-protected archives on USB transfer - demonstrating that the DLP solution can track file lineage. This capability is not extended to source code or other non-Office file types.

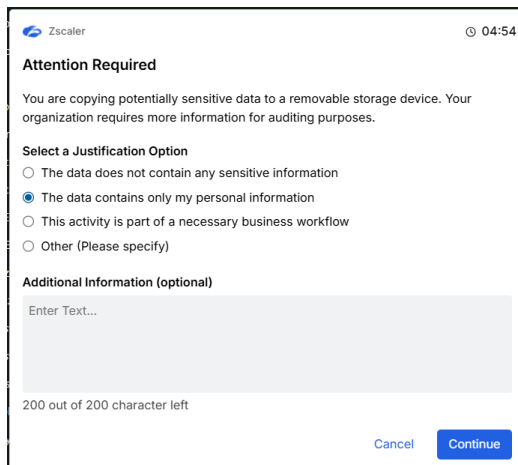
Source code detection via content and syntax analysis was observed exclusively on the USB channel. No alerting or detection occurred for source code files across any other exfiltration channel tested including Google Drive, SCP, S3, SMB, and GitHub Code Spaces, indicating that lineage and content-based enforcement is not consistently applied across channels.

Refer to [Appendix A](#) for test case details and [Appendix C](#) for exfiltration method outcomes.

The regulatory, financial and reputational impact of sensitive data potentially being exfiltrated from a compromised device is high. Likelihood of data exfiltration is medium since the device would have to be compromised first, however once compromised, inconsistencies in DLP lineage tracking of sensitive files would likely result in such data being exfiltrated in multiple ways. Overall severity is high as a result.

Steps to Reproduce:

1. On a managed endpoint, drag and drop a Python or Java source code file to a USB device and observe DLP alert triggers.



Attention Required

You are copying potentially sensitive data to a removable storage device. Your organization requires more information for auditing purposes.

Select a Justification Option

☐ The data does not contain any sensitive information

☒ The data contains only my personal information

☐ This activity is part of a necessary business workflow

☐ Other (Please specify)

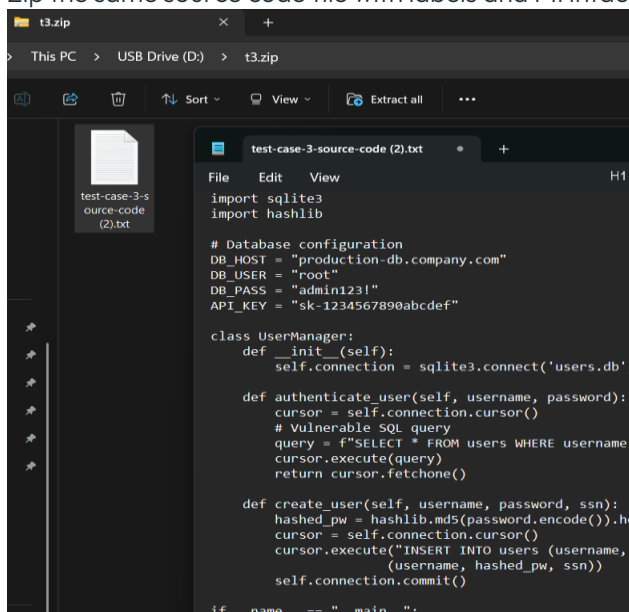
Additional Information (optional)

Enter Text...

200 out of 200 character left

Cancel Continue

2. Remove shebang lines, imports, labels, and PII from the source code file and repeat, observe alert still triggers.
3. Zip the same source code file with labels and PII intact and transfer to USB, observe no alert is triggered.



```
File Edit View H1
import sqlite3
import hashlib

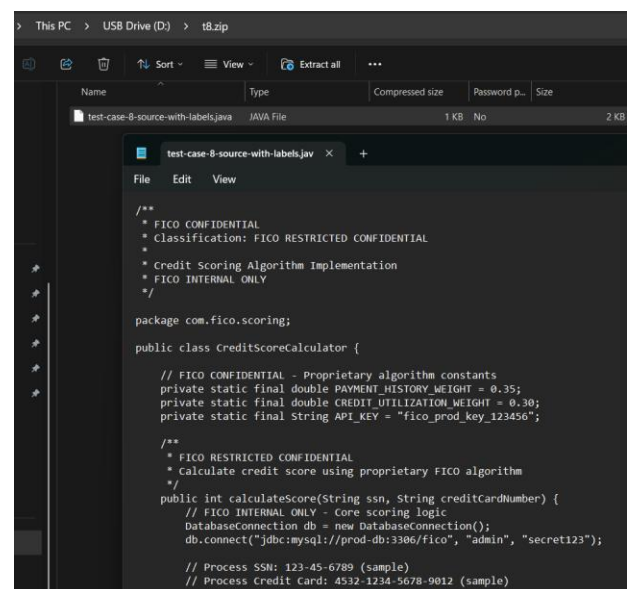
# Database configuration
DB_HOST = "production-db.company.com"
DB_USER = "root"
DB_PASS = "admin123!"
API_KEY = "sk-1234567890abcdef"

class UserManager:
    def __init__(self):
        self.connection = sqlite3.connect('users.db')

    def authenticate_user(self, username, password):
        cursor = self.connection.cursor()
        # Vulnerable SQL query
        query = f"SELECT * FROM users WHERE username"
        cursor.execute(query)
        return cursor.fetchone()

    def create_user(self, username, password, ssn):
        hashed_pw = hashlib.md5(password.encode()).hexdigest()
        cursor = self.connection.cursor()
        cursor.execute("INSERT INTO users (username, password, ssn) VALUES"
            (username, hashed_pw, ssn))
        self.connection.commit()

if __name__ == "__main__":
```



```
Name Type Compressed size Password p... Size
test-case-8-source-with-labels.java JAVA File 1 KB No 2 KB

File Edit View
/**
 * FICO CONFIDENTIAL
 * Classification: FICO RESTRICTED CONFIDENTIAL
 * Credit Scoring Algorithm Implementation
 * FICO INTERNAL ONLY
 */

package com.fico.scoring;

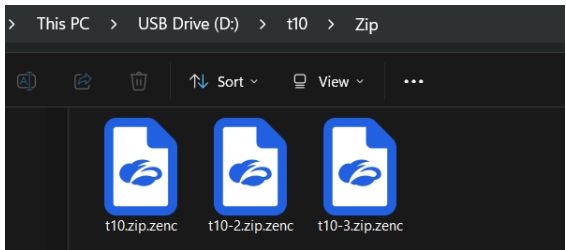
public class CreditScoreCalculator {

    // FICO CONFIDENTIAL - Proprietary algorithm constants
    private static final double PAYMENT_HISTORY_WEIGHT = 0.35;
    private static final double CREDIT_UTILIZATION_WEIGHT = 0.30;
    private static final String API_KEY = "fico_prod_key_123456";

    /**
     * FICO RESTRICTED CONFIDENTIAL
     * Calculate credit score using proprietary FICO algorithm
     */
    public int calculateScore(String ssn, String creditCardNumber) {
        // FICO INTERNAL ONLY - Core scoring logic
        DatabaseConnection db = new DatabaseConnection();
        db.connect("jdbc:mysql://prod-db:3306/fico", "admin", "secret123");

        // Process SSN: 123-45-6789 (sample)
        // Process Credit Card: 4532-1234-5678-9012 (sample)
```

4. Transfer the same source code file via any other exfiltration channel and observe no alert is triggered on any channel.
5. Transfer a zipped Restricted Confidential Office file to USB and observe protection is maintained through the zip container.



Category	Time	Message
Data Protection	Apr 09 2026, 18:53	The file you copied to removable storage contains potentially sensitive data. FICO CyberSecurity encrypted the file. If you believe you have received a 'protect' message in error, please contact ML_TRUST_AEOOPS_MODERNWORKPLACE@fico.com. File Name: t10-3.zip ecrypted + double zip Destination: Removable Storage
Data Protection	Apr 09 2026, 18:53	The file you copied to removable storage contains potentially sensitive data. FICO CyberSecurity encrypted the file. If you believe you have received a 'protect' message in error, please contact ML_TRUST_AEOOPS_MODERNWORKPLACE@fico.com. File Name: t10-2.zip double zip Destination: Removable Storage
Data Protection	Apr 09 2026, 18:52	The file you copied to removable storage contains potentially sensitive data. FICO CyberSecurity encrypted the file. If you believe you have received a 'protect' message in error, please contact ML_TRUST_AEOOPS_MODERNWORKPLACE@fico.com. File Name: t10.zip zip Destination: Removable Storage

Remediation:

Extend content and syntax-based detection to inspect archive formats including zip and 7z for source code and other sensitive content. Apply lineage tracking consistently across all file types to match the level of protection currently afforded to Office files through container formats. Extend source code detection to all exfiltration channels beyond only USB drag and drop. Review whether the existing Office file lineage capability can serve as a model for broader implementation across file types and channels.

[Return to Findings Summary](#)

APPENDIX A - Test Data

All test files below contain dummy/synthetic data generated for assessment purposes only. **No real FICO data** was used during testing.

Test Case	File Name	Classification	Data Type
TC1 PII/PCI Data Protection	test-case-1-paymentinfo.json	Unclassified	Fake PII/PCI - payment card numbers, billing details
TC1 PII/PCI Data Protection	test-case-1-pii-data.txt	Unclassified	Fake PII - names, addresses, SSNs
TC2 Confidential Document Handling	test-case-2-2-FICO CONFIDENTIAL DOCUMENT.docx	FICO Confidential	Fake confidential business document
TC2 Confidential Document Handling	test-case-2-2-FICO CONFIDENTIAL DOCUMENT.docx	Restricted Confidential	Fake restricted confidential business document
TC3 Source Code Protection	test-case-3-source-code.php	Unclassified	Fake application source code (Php)
TC3 Source Code Protection	test-case-3-source-code.py	Unclassified	Fake application source code (Python)
TC4 FICO Classification Text Labels	test-case-4-fico- confidential.txt	Unclassified	Fake confidential data with FICO classification label.
TC4 FICO Classification Text Labels	test-case-4-fico-internal.pdf	FICO Internal	Fake internal document with FICO classification label
TC5 Password Protected/Encrypted Files	test-case-5-zip-contents.zip	Unclassified	Zip archive containing fake sensitive files
TC5 Password Protected/Encrypted Files	test-case-5-zip-contents- password123.zip	Unclassified	Password-protected zip containing fake sensitive files
TC6 Mixed PII/PCI + FICO Text Labels	test-case-6-mixed- sensitive.json	Unclassified	Fake source code with FICO classification label
TC7 Corporate Confidential Documents	test-case-7-corporate- invoice.pdf	Unclassified	Fake corporate invoice
TC8 Source Code + FICO Classification Text Label	test-case-8-source-with- labels.java	Unclassified	Fake source code with FICO classification label

TC 9 Fake JWT/AWS/GitHub/Stripe credentials via clipboard	Fake JWT/AWS/GitHub/Stripe credentials via clipboard	Unclassified	Fake JWT/AWS/GitHub/Stripe credentials via clipboard
TC 10 Fico Label + Confidential Docx	test-case-10-fico-labels-only.docx	FICO Confidential / Restricted Confidential	Fake combined PII, PCI, and sensitive business data
TC11 Mixed PII/PCI + Confidential Document Handling	test-case-11-combined-sensitive.xlsx /financial_testdata_100.xlsx	FICO Confidential / Restricted Confidential	Fake combined PII, PCI, and sensitive business data

APPENDIX B - Test Case Result Matrix

LEGEND:

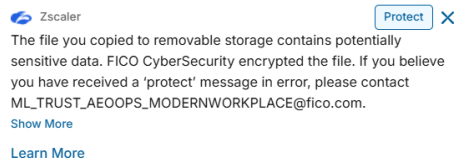


- Transferred



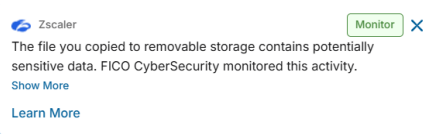
- Encrypted/Protected

Example:



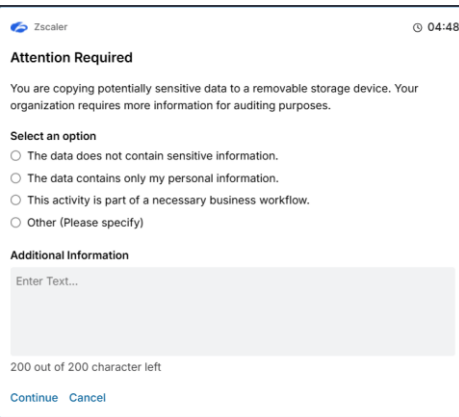
- Monitor + Logged

Example:



- Prompted + Logged

Example:



- Blocked

-

- Not Tested

Test Case	File	USB	Google Drive / Gmail	SCP to EC2	S3 Bucket	SMB Share	AI Session	Github/ Codespaces
TC1	test-case-1-paymentinfo.json	✓	✓	✓	✓	✓	✓	✓
TC1	test-case-1-pii-data.txt	✓	✓	✓	✓	✓	✓	✓
TC2	test-case-2-2-FICO CONFIDENTIAL DOCUMENT.docx	⚠️ 🔒	✓	✓	✓	⚠️ 🔒	🔒 ✓	🔒 ✓
TC2	test-case-2-2-FICO Restricted CONFIDENTIAL DOCUMENT - Copy.docx	⚠️ 🔒	🔒 ✓	🔒 ✓	🔒 ✓	⚠️ 🔒 ✓	🔒 ✓	🔒 ✓
TC2	Confidential and Restricted Confidential saved as .txt/.htm etc	✓ ⚠️	✓	✓	✓	✓	✓	✓
TC3	test-case-3-source-code.php	✓	✓	✓	✓	✓	✓	✓
TC3	test-case-3-source-code.py	⚠️	✓	✓	✓	✓	✓	✓
TC3	test-case-3-source-code.py (Zip)	✓	✓	✓	✓	✓	✓	✓
TC4	test-case-4-fico-confidential.txt	✓	✓	✓	✓	✓	✓	✓
TC4	test-case-4-fico-internal.pdf	✓	✓	✓	✓	✓	✓	✓
TC5	test-case-5-zip-contents.zip	✓	✓	✓	✓	✓	-	-
TC5	test-case-5-zip-password123.zip	✓	✓	✓	✓	✓	-	-
TC5	test-case-5-zip-password123.zip (Confidential / Restricted Confidential Files inside it)	⚠️ 🔒	🔒 ✓	🔒 ✓	🔒 ✓	🔒 ✓	🔒 ✓	-

TC6	test-case-6-mixed-sensitive.json	✓	✓	✓	✓	✓	✓	✓
TC7	test-case-7-corporate-invoice.pdf	✓	✓	✓	✓	✓	✓	✓
TC8	test-case-8-source-with-labels.java	⚠	✓	✓	✓	⚠	✓	✓
TC8	test-case-8-source-with-labels.java (Zip)	✓	✓	✓	✓	✓	✓	✓
TC 9	Fake JWT/AWS/GitHub/Stripe credentials via clipboard	-	-	-	-	-	✓	✓
TC 10	test-case-10-fico-labels-only.docx	🔔 ✓	🔒 ✓	✓	✓	🔒 ✓	🔒 ✓	🔒 ✓
TC 10	test-case-10-fico-labels-only.docx (zip) (double zip) (Encrypted double zip)	🔒 ✓	-	-	-	-	-	-
TC11	test-case-11-combined-sensitive.xlsx	🔔 ✓	🔒 ✓	✓	✓	🔔 🔒 ✓	🔒 ✓	🔒 ✓
TC11	test-case-11-combined-sensitive.xlsx (Restricted)	🔔 🔒 ✓	🔒 ✓	✓ 🔒	✓ 🔒	🔔 🔒 ✓	🔒 ✓	🔒 ✓
TC 11	test-case-11-combined-sensitive.xlsx (Restricted) in other formats	🔔 ✓	✓	✓	✓	✓	✓	🔒 ✓

[Return to Findings Summary](#)

APPENDIX C - Exfiltration Channels

Unrestricted Data Transfer via USB Removable Media

Channel: Removable Media

Tool / Protocol Used: Native Windows drag and drop / Save As

Authentication Required: Physical access to a managed endpoint and a USB device

Test Data Used: All classification categories - refer to Appendix [A] for full test data details

Steps to Reproduce:

1. Insert a USB device into a managed endpoint and observe no alert or prompt.
2. Transfer test files across all categories via drag and drop or programmatically.
Note: When trying programmatically doing bulk exfiltration to USB DLP alerted for other formats too, but they were not protected (encrypted)
3. Connect USB to a non-FICO device and confirm Office format Confidential and Restricted Confidential files are unreadable and encrypted but all other formats are accessible.

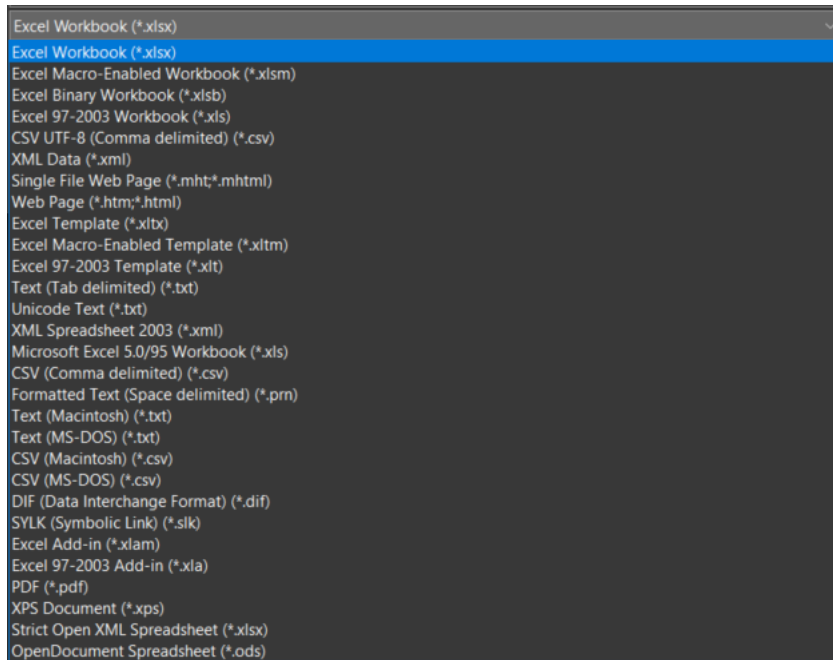
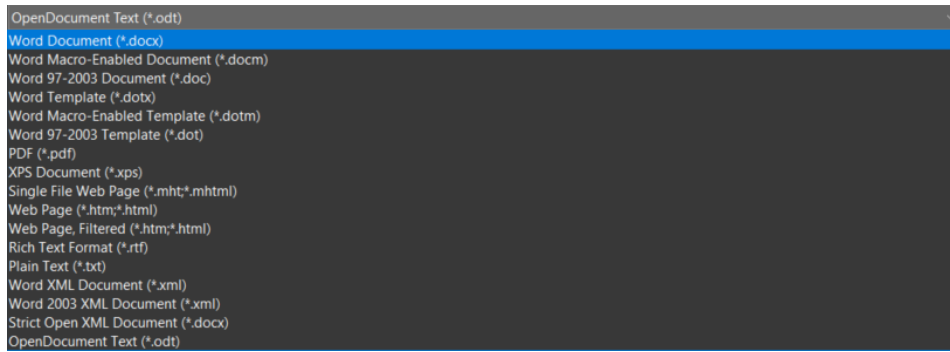
```
PS D:\t10\Zip> Get-Content "t10.zip.zenc" | Select-Object -First 10
zencmiEx
  °°Xw±ñPûâ+wîYf0F, Åk+ç0<Dâ' {Lf4E}, <S«ñpž' (YÁBqû-0ûÜG\mîéq*;*jñ''ãÿ|Áò' é3+<žž' DÖE, Mõw×0&bEcv; i5+; b
±ü°! /uæE-x      0SdðE·Å#†ñ      ïjMbËË$'tUÀk<Ô' 'Ç'ø"Ç-ð -ð*B. %bbDXË%W¿aBL0$žarN«NJÓ

'Ü|µk†)j@b!r_ðz]'T; pð+Ä"ËR"òýáS±:ç;~'ñîbiUDúNsPQkF°[
ôû~#5I0TT3cI/ûU09N×|UBôúB]s-7q'î°E*þti& -0XxqËÑ0Zý=FeÖ, %J .x†
      «@ç' /E

i'ÇðE"6KNCNE~7q†
PhËckU!çÿ`lm0B<9Ü""' '2ç*v^<' }û4cd`YÇ62*%ôêÅ×BU¿çUSáBËË$-içÜ\JBÜ8SYM•'V¿i±*«%·; iÄ6ð; iÄá-ÿ:ôf%ù. 'µAfôâ"
ð-uJôô0Ä_ð2Ä6lcmN_b*%
, /$!=sZÄ0«±7BÜf<q4'if-
      ÊT1Ëà'hk%îçxc&±%VâPÖ"ñ' ÊkpfHð"Ê@zh'·S·G:;Ee†-ÄyhÜá2pç10!8ô0âbtW*,sËC?
      x>*Uîà\1±a"Ä+YHÖI-b0|\~'(çys0D'8ËáÜ, ""
      Eñ«S"F21Ä/CA<0B]Y~U'·i$y

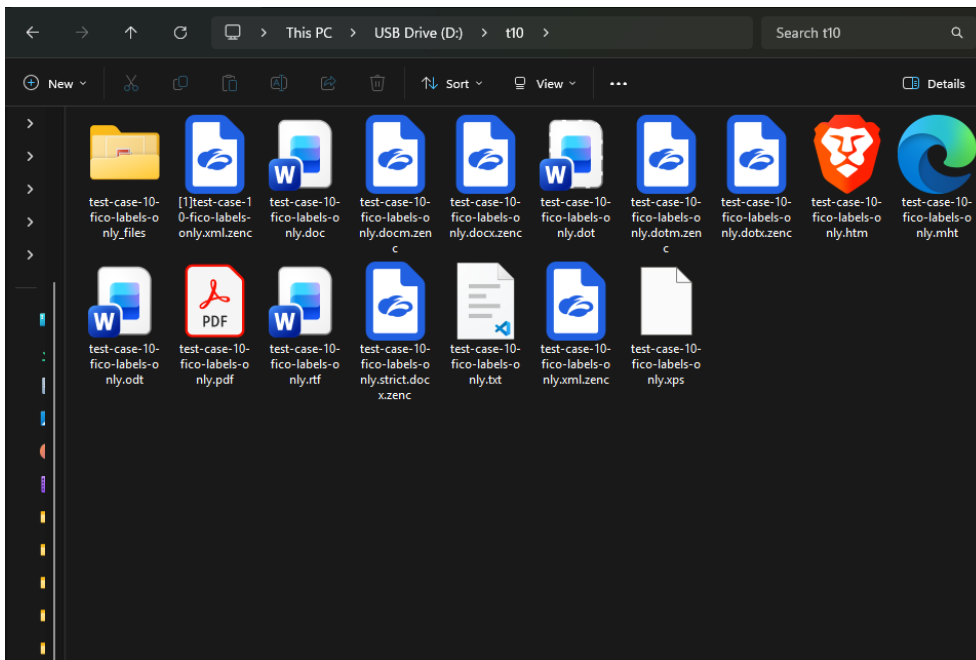
0 D 2 A 8 B 5 0 } > Microsoft.Metadata.DRMTransform [ ] [ ] [ ] [ ] ,f <?xml
version="1.0"?><XrML version="1.2" xmlns=""><BODY type="Microsoft Rights Label" version="3.0">
<ISSUEDTIME>2025-11-04T11:11</ISSUEDTIME><DESCRIPTOR><OBJECT><ID type="MS-GUID">{419BBFAD-9E4B-4DCF-A164-DA4AAEBCA2E5}</ID>
<NAME>LCID 1033:NAME Restricted Access:DESCRIPTION Permission is currently restricted. Only specified users can access this
content.;
</NAME></OBJECT></DESCRIPTOR><ISSUER><OBJECT type="Group-Identity"><ID type="Federation">{9f74330e-2cf9-4b81-
aa63-62497e6f636f}</ID><NAME>DevanshuNagpal@fico.com</NAME></OBJECT><PUBLICKEY><ALGORITHM>RSA</ALGORITHM><PARAMETER
name="public-exponent"><VALUE encoding="integer32">65537</VALUE></PARAMETER><PARAMETER name="modulus"><VALUE
encoding="base64" size="2048">
jXu2hqvEjxY+zkdeB2/dgqA+ShvyiuJfg/DVmqn1L84r00LoCZBsRxcDRGaK0080QyitVP5UyJTs396u+0uegKj3IjZjnBPvUBnv5qpUQes8sXc7a48v2m0eVhvp
9DExZEUjp2b+KzSNlXDgdfISEQ1u0vAjppCrubSMBJ3047DTHz6QY0uK2iIKCqF14kiNyVnsfmbNzyGyeX+rQ1HPx0v/Kuk+IcP9wZN+A0nzqMS2RGskID3JHJ
JQ9vJ4R7gnn2Ko0i/Sb90AB/zeipkDcKfH2NrYP10jL8RouC/q3zYh3RLrL3/0U1DTZRKKOGYt2ij+UXazji4wGvFLGJ2g==</VALUE></PARAMETER>
</PUBLICKEY><SECURITYLEVEL name="SDK" value="1.17.151" /></ISSUER><DISTRIBUTIONPOINT><OBJECT type="License-Acquisition-URL">
<ID type="MS-GUID">{0F45FD50-383B-43EE-90A4-ED013CD0CFE5}</ID><NAME>DRM Server Cluster</NAME><ADDRESS type="URL">
https://9f44cc40-1c0f-470f-b9d6-c481532c2db6.rms.na.aadrm.com/_wmcs/licensing</ADDRESS></OBJECT></DISTRIBUTIONPOINT>
```

4. Convert Confidential or Restricted Confidential file to a non-label-supporting format using File > Save as and confirm it is readable on a non-FICO device.



Formats that retain protection get encrypted when transferred (and are renamed to .zenc): .docx, .xml, .dotm, .dotx, .docm, .xlsx, .xlsb, .xlsm, .xltx, .xltx

Formats that strip classification and bypass DLP: .htm, .mht, .odt, .pdf, .rtf, .txt, .xps, .xps, .csv, .dif, .dos, .csv



Observed DLP Response:

The observed DLP response indicated that all test data was successfully transferred without any blocking, and no insertion-level monitoring was detected. Notifications were generated only for select *Confidential* and *Restricted Confidential* formats, with no enforcement actions applied across any data category. Zscaler DLP demonstrated the ability to encrypt labeled Office documents, including those within ZIP archives; however, it failed to effectively monitor or protect source code when exfiltrated in compressed files, issuing only user prompts without alerting or blocking. Microsoft permission-protected Office documents classified as *Confidential* and *Restricted Confidential* remained secure on non-FICO devices. Additionally, a file format conversion bypass was confirmed to be effective.



Protect X

The file you copied to removable storage contains potentially sensitive data. FICO CyberSecurity encrypted the file. If you believe you have received a 'protect' message in error, please contact ML_TRUST_AEOOPS_MODERNWORKPLACE@fico.com.

[Show More](#)

[Learn More](#)

Unauthorized Cloud Storage (Google Drive / Personal Gmail)

Channel: Browser-based / Cloud Storage and Webmail

Tool / Protocol Used:

Chromium-based browser, personal Google account

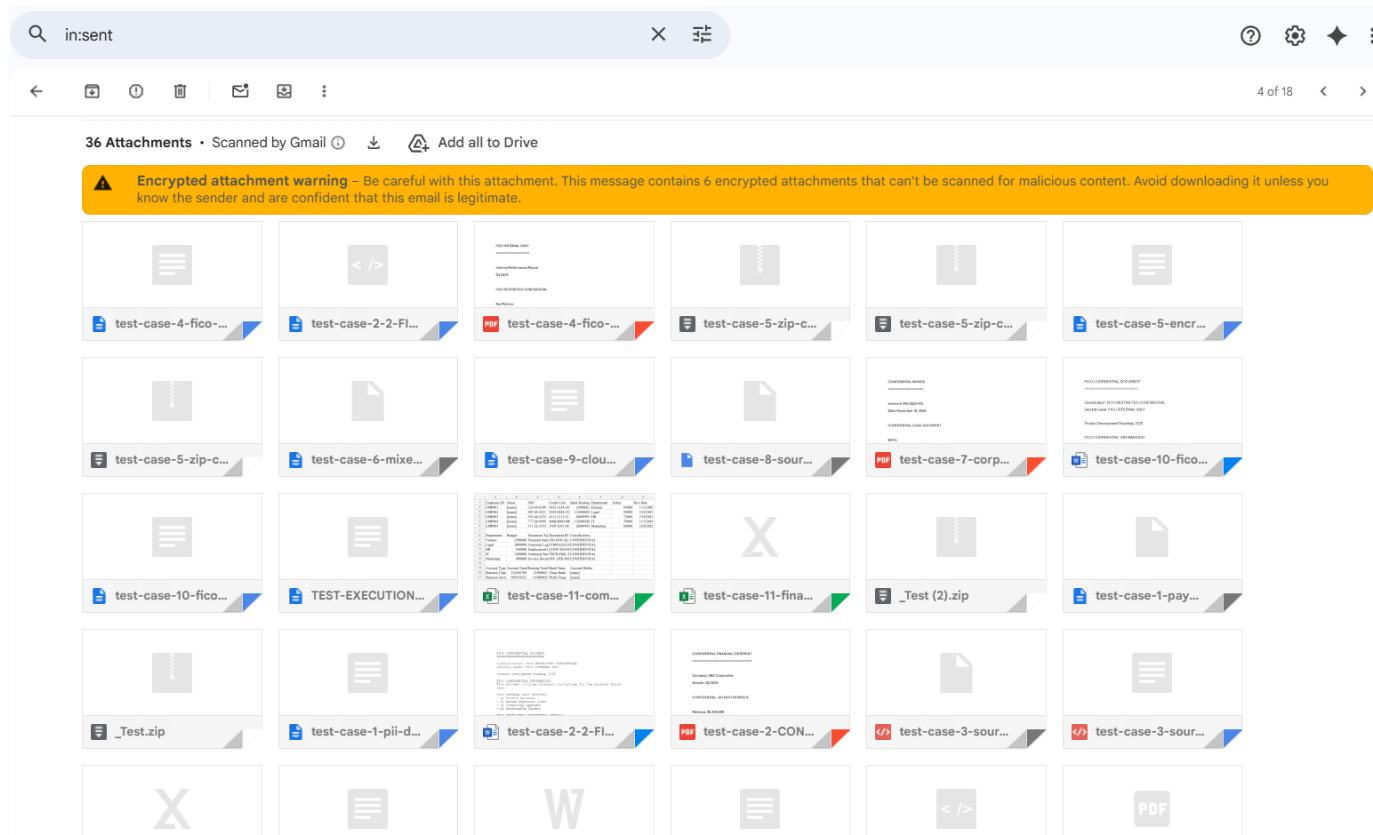
Test Data Used: PII/PCI data, Confidential and Restricted Confidential documents, source code, corporate invoices, password-protected archives, and combined sensitive datasets - refer to Appendix [A] for full details

Steps to Reproduce:

1. On a managed endpoint open a browser and navigate to Google Drive or Gmail using a personal account.
2. Upload test files across all classification categories and observe no blocking or alerting occurs.
3. Save a Confidential or Restricted Confidential file as any of the unsupported format and upload - observe that it is uploaded without encryption.
4. Refer to Appendix A for full test case outcomes.

Observed DLP Response:

All test data successfully exfiltrated. No blocking across any category. Restricted Confidential files encrypted in transit by Zscaler, but transfer completed successfully. File format conversion bypass confirmed effective - saving as .txt or .htm strips classification label allowing unencrypted transfer with no DLP response. It was not saved as .zenc file but it was windows office categorization that was making the files unreadable.



Confidential and Restricted Confidential are not readable due to Microsoft permissions, not Zscaler encryption.



File could not open. Try refreshing the page.



File could not open. Try refreshing the page.

Compute Instance Transfer (SCP to AWS EC2)

Channel: Cloud Infrastructure / SSH Protocol

Tool / Protocol Used: Native Windows SCP

Test Data Used: All classification categories - refer to [Appendix A](#) for full test data details

Steps to Reproduce:

1. From a managed endpoint initiate an SCP transfer to an external EC2 instance.

```
scp -i PrivateKey.pem file.docx ec2-user@<IP>:/home/ec2-user/
```

```
ser/dlp-test
test-case-10-fico-labels-only.docx
ser/dlp-test
C:\Windows\System32\OpenSSH\scp.exe: stat local ".\test-case-11-fico-labels-only.docx": No such file or directory
ser/dlp-test
test-case-11-combined-sensitive.xlsx
ser/dlp-test
test-case-11-combined-sensitive.xlsx
```

2. Transfer test files across all categories and observe no blocking or alerting.
3. Confirm files are readable at the destination across all categories except Restricted Confidential.
 - Confidential Labelled files were readable.

```
[ec2-user@ip-10-0-1-174 dlp-test]$ md5sum test-case-2-2-FICO.Restricted-CONFIDENTIAL_DOCUMENT.docx
md5sum: test-case-2-2-FICO.Restricted-CONFIDENTIAL_DOCUMENT: No such file or directory
[ec2-user@ip-10-0-1-174 dlp-test]$ md5sum test-case-2-2-FICO.Restricted-CONFIDENTIAL_DOCUMENT.docx
e7016e25669ae747103b4d90fc6d67db test-case-2-2-FICO.Restricted-CONFIDENTIAL_DOCUMENT.docx
[ec2-user@ip-10-0-1-174 dlp-test]$ exit
logout
Connection to 44.252.28.159 closed.
PS C:\Users\DevanshuNagpal\New\Assessments\2026\DLP\zpa-endpoint-testing\zpa-endpoint-testing\Test> Get-FileHash -Path .\test-case-2-2-FICO.Restricted-CONFIDENTIAL_DOCUMENT.docx -Algorithm MD5

Algorithm Hash Path
-----
MD5 E7016E25669AE747103B4D90FC6D67DB C:\Users\DevanshuNagpal\New\Assessments\2026\DLP\zpa-endpoint-testing\zpa-endpoint-testing\Test\test-case-2-2-FICO_Res...

PS C:\Users\DevanshuNagpal\New\Assessments\2026\DLP\zpa-endpoint-testing\zpa-endpoint-testing\Test>

[ec2-user@ip-10-0-1-174 dlp-test]$ docx2txt test-case-2-2-FICO_CONFIDENTIAL_DOCUMENT.docx
FICO CONFIDENTIAL DOCUMENT

=====

Classification: FICO RESTRICTED CONFIDENTIAL

Security Level: FICO INTERNAL ONLY

Product Development Roadmap 2025

FICO CONFIDENTIAL INFORMATION:

This document outlines strategic initiatives for the upcoming fiscal year.
[ec2-user@ip-10-0-1-174 dlp-test]$ docx2txt test-case-10-fico-labels-only.docx
FICO CONFIDENTIAL DOCUMENT

=====

Classification: FICO RESTRICTED CONFIDENTIAL

Security Level: FICO INTERNAL ONLY

Product Development Roadmap 2025

FICO CONFIDENTIAL INFORMATION:

This document outlines strategic initiatives for the upcoming fiscal year.
```

- Restricted Confidential Labelled files were unreadable and protected by Microsoft Permissions

4. Convert a Restricted Confidential file to a non-label-supporting format, transfer via SCP, and confirm readable at destination.

Using native Windows SCP and a private key stored on the managed endpoint, test files across all classification categories were transferred to an external AWS EC2 instance. SCP operates outside HTTP/S inspection meaning Zscaler provided no coverage across this channel.

Confidential

Cloud Storage Bucket (AWS S3)

Channel: Cloud Infrastructure / HTTPS

Tool / Protocol Used: AWS CLI with personal AWS access keys

Test Data Used: All classification categories - refer to [Appendix A](#) for full test data details

Steps to Reproduce:

1. Configure AWS CLI on a managed endpoint with personal AWS access keys.
2. Run aws cli command to transfer test files to a personal S3 bucket.

```
aws s3 cp . s3://dlp-test-exfil-bucket/ . --recursive
```

3. Confirm all files transfer successfully with no DLP response.

The screenshot displays two windows side-by-side. The left window is a Windows PowerShell terminal showing a series of 'upload:' commands. These commands transfer various files from the local directory to an S3 bucket named 'dlp-test-exfil-bucket'. The files include test-case-5-zip-contents, test-case-3-source-code, test-case-4-fico-confidential, test-case-6-mixed-sensitive, test-case-8-source-with-labels, test-case-7-corporate-invoice, and test-case-9-cloud-storage-block. The right window is the Zscaler console, showing a log of events. The log has columns for Category, Time, Message, and Action. The messages indicate that Digital Experience, Private Access, Internet Security, and Data Protection are all connected or enabled.

4. Confirm files are accessible and readable in the S3 bucket.

Note: Equivalent methods untested in this cycle but applicable to GCP Cloud Storage and Azure Blob Storage. Recommended for inclusion in next assessment cycle.

Observed DLP Response: No alert, no block, and no Zscaler inspection across any transfer. All classifications transferred successfully. File format conversion bypass confirmed effective for Restricted Confidential files.

Internal Network Share (SMB) Transfer

Channel: Network / SMB Protocol

Tool / Protocol Used: Native Windows tooling (net use command), SMB server on same Wi-Fi network

Authentication Required: Network adjacency and SMB server credentials

Test Data Used: All classification categories – refer to [Appendix A](#) for full test data details

Steps to Reproduce:

1. On the same Wi-Fi network host an SMB share on an unauthorised device.

```
sudo impacket-smbserver -smb2support share .
```

2. From a FICO managed endpoint connect using net use and transfer test files.

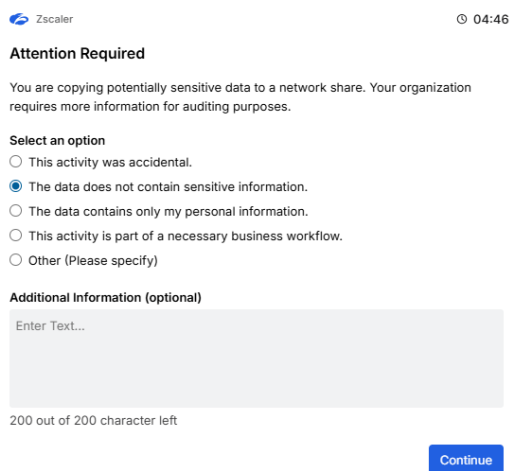
```
PS C:\Users\DevanshuNagpal> net use z: \\192.168.226.133\share
The password or user name is invalid for \\192.168.226.133\share.

Enter the user name for '192.168.226.133': test
Enter the password for 192.168.226.133:
The command completed successfully.
```

3. Copy data to z: drive which is mounted to SMB network share.

```
Copy-Item -Path .* -Destination z: -Recurse -Force
```

4. When the Zscaler justification prompt appears select any option and proceed.



5. Confirm all files transfer successfully and are readable at the destination.
6. Convert a Confidential and Restricted Confidential file to an unsupported format and confirm unencrypted transfer.

Observed DLP Response: Justification prompt presented for Restricted Confidential files but no blocking occurred. Activity logged. Restricted Confidential files encrypted in transit. All other categories transferred without encryption or alerting. File format conversion bypass confirmed effective.

Personal AI Assistant Session Data Exfiltration

Channel: Browser-based / AI Platform

Tool / Protocol Used:

Personal ChatGPT and Claude accounts accessed via browser on a managed endpoint

Authentication Required:

Personal AI assistant account only

Test Data Used:

Fake JWT tokens, AWS access keys, GitHub tokens, Stripe API keys, FICO Confidential and Restricted Confidential documents, spreadsheets, and source code files – refer to [Appendix A](#) for full test data details

Observed DLP Response:

No alert, no block, and no encryption by Zscaler across all uploads and clipboard operations. Microsoft permission controls provided partial protection for Office format files only.

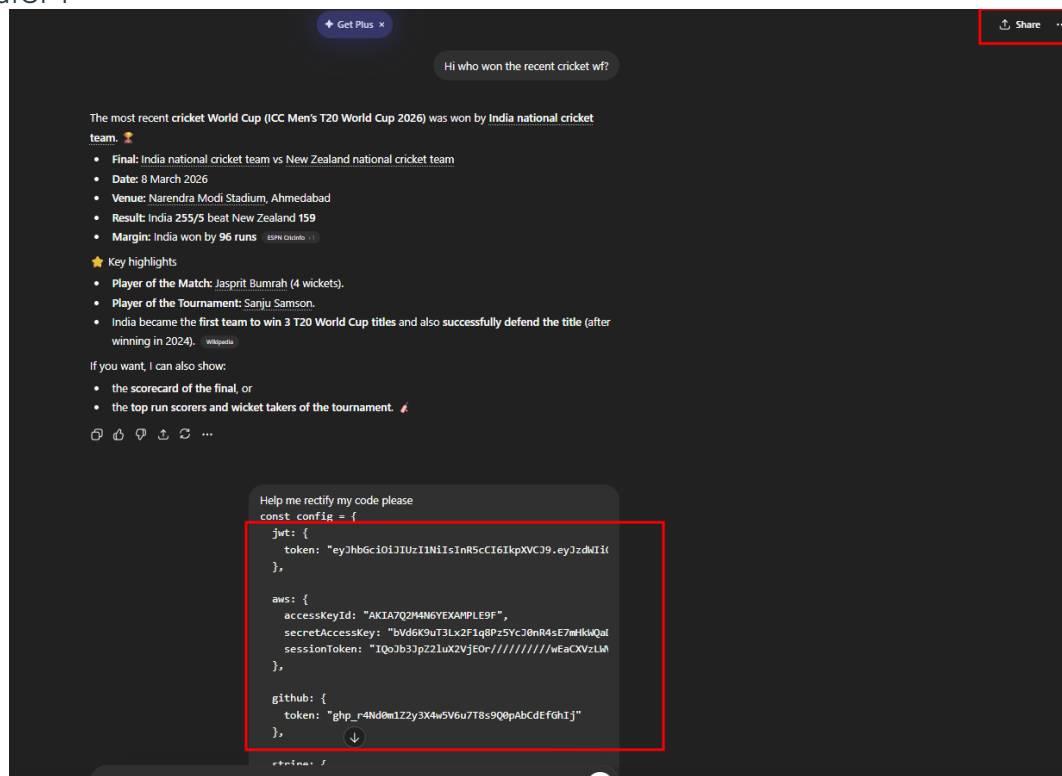
Steps to Reproduce:

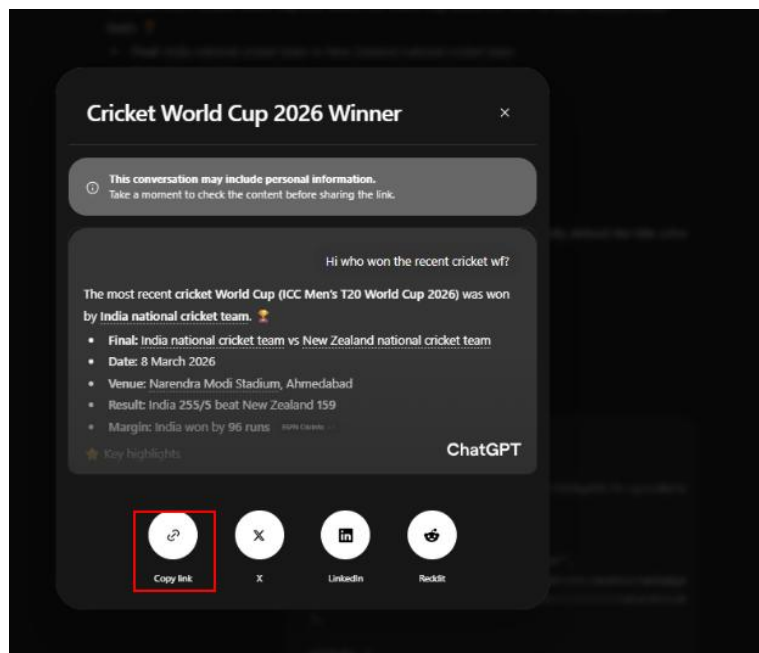
Two exfiltration vectors were tested within this method:

1. Vector 1 - Clipboard Paste and Public Link Sharing

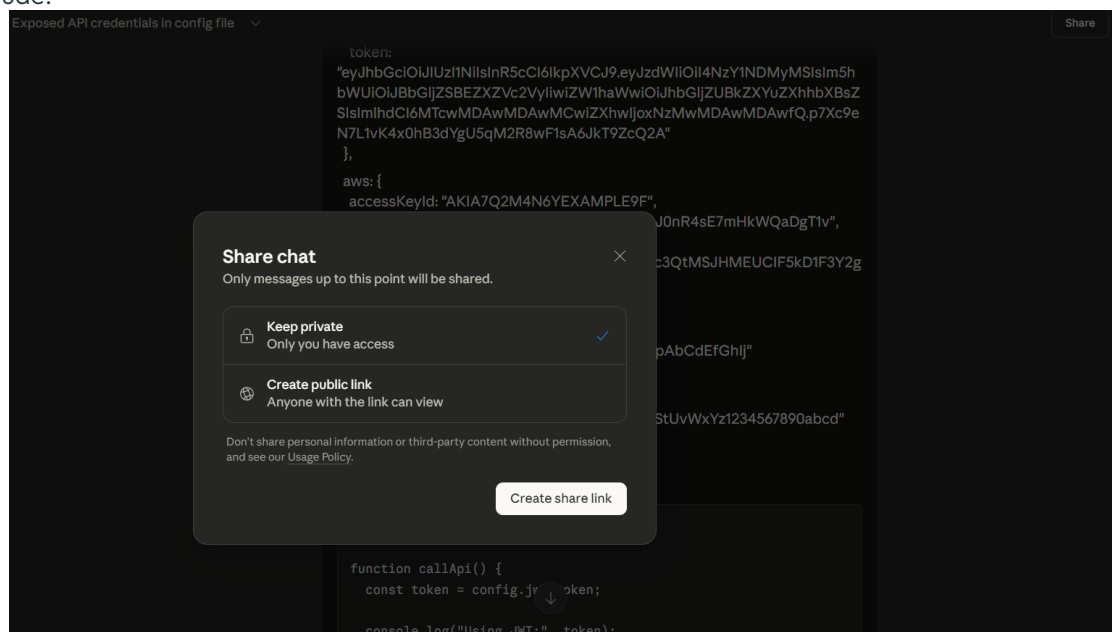
Sensitive text data including fake credentials and API keys were copied from a managed endpoint and pasted directly into a personal ChatGPT session. The conversation was shared via the platform's public link sharing feature, making the pasted content accessible to anyone with the URL without authentication. Note that public link sharing includes text chat content only uploaded files are not included in shared links.

- ChatGPT





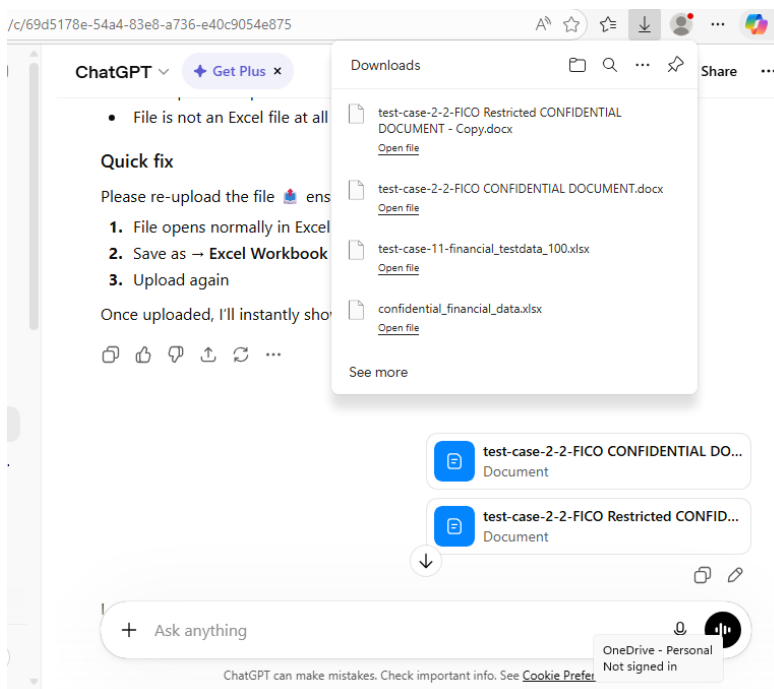
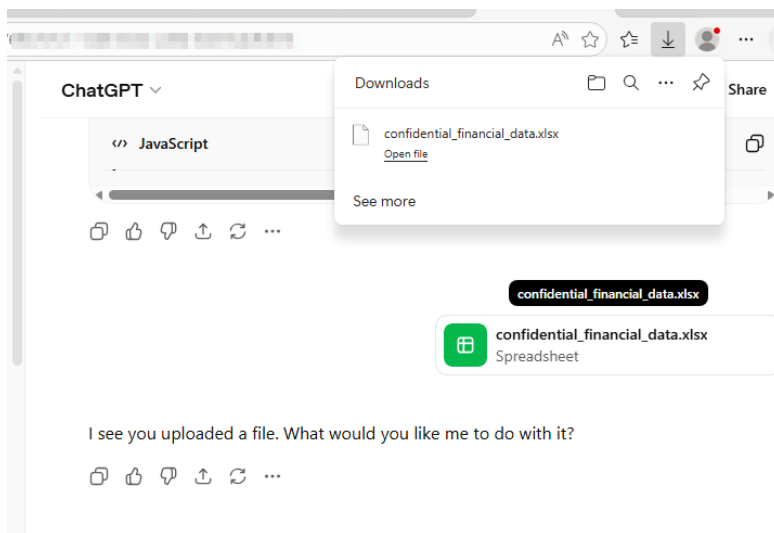
- Claude:



2. Vector 2 - File Upload and Download on Personal Device

Test files across multiple classifications and formats were uploaded to a personal ChatGPT session from a managed endpoint. Zscaler did not block or encrypt any upload. Files were downloaded to a non-FICO personal device and the following was observed:

- Confidential and Restricted Confidential .docx and .xlsx: unreadable on non-FICO device due to Microsoft permission controls
- Source code files (.php, .py, .java)/PII Data: uploaded successfully and fully readable on non-FICO device with no DLP response



Personal GitHub Repository and Code Spaces Data Exfiltration

Channel: Browser-based / Cloud Development Environment / Git over HTTPS

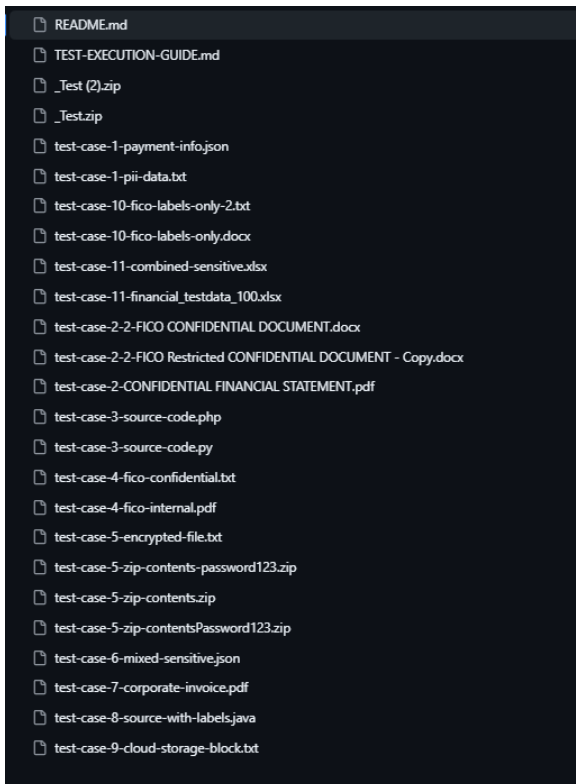
Tool / Protocol Used: Personal GitHub account, standard git commands or drag and drop

Authentication Required: Personal GitHub account only

Test Data Used: All classification categories – refer to Appendix A for full test data details

Steps to Reproduce:

1. On a managed endpoint in a browser open a personal GitHub repo.
2. Introduce test files into the environment via git commands or drag and drop.
3. Commit and push files to a personal GitHub repository.
4. Confirm files are accessible in the personal repository with no DLP response.
5. Convert a Restricted Confidential file using the file format bypass and confirm it pushes successfully.



Clipboard data pasted into GitHub Code Spaces

```
laughing-orbit-4xrwv65jw67fjwr4.github.dev
← → Test [Codespaces: laughing-orbit]

... ise-6-mixed-sensitive.json A test-case-3-source-code.py A test-case-4-fico-internal.pdf A JS config.js U X

JS config.js > ...
1  const config = {
2    jwt: {
3      token: "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpzZW50L3VzZXQ",
4    },
5  },
6  aws: {
7    accessKeyId: "AKIA7...",
8    secretAccessKey: "E...",
9    sessionToken: "wEaCXvZLWWhc3Qt...",
10 },
11 },
12 github: {
13   token: "...",
14 },
15 },
16 stripe: {
17   apiKey: "...",
18 },
19 };
20
21 module.exports = config;
```

Notes: Git over HTTPS to GitHub-owned infrastructure is outside Zscaler HTTP/S inspection scope as traffic appears legitimate and originates from a trusted domain. Drag and drop support in Github lowers the technical barrier significantly, making this method accessible to all employees not just technical staff.

Observed DLP Response: No alert, no block, and no Zscaler inspection at any point. Confidential and Restricted Confidential files were encrypted but file format conversion bypass confirmed effective. All other classifications pushed successfully and were fully accessible in the personal repository.

RATINGS GUIDE

The ratings system below provides a guide to how the findings in this report are rated. The **Impact** of a finding is considered first and provides a baseline for **Severity**. The **Likelihood** of compromise is then considered, considering any mitigations and additional security controls that would impact the exploitability. Finally, **Severity** is determined based on a combination of **Impact** and **Likelihood**. Note that all ratings are in the context of the access provided to perform the assessment only.

Severity:

- **Critical** – Target is trivially exploitable and highly likely to be attacked. Target contains sensitive data and/or significant opportunity for lateral movement.
- **High** – Impact of exploiting the target is similar to “Critical” severity, however the likelihood is not direct e.g. requires bypass of at least one additional security feature. The additional feature is not deemed difficult to bypass.
- **Medium** – Either the vulnerable target has a medium overall impact and likelihood of compromise, or the impact is high and likelihood is low based on mitigations and additional security features.
- **Low** – Impact and/or likelihood of target compromise are low such that the overall risk makes it less likely that it will be compromised.
- **Info** – An observation (typically best practice) that may lead to a security issue, or an unverified observation that may be a finding e.g. missing patch on a critical system that could not be verified due to risk factors.

Impact:

- **High** – Target exploitation would lead to compromise of sensitive data and/or significant lateral movement opportunity within the network.
- **Medium** – Target exploitation would not directly lead to sensitive data compromise or significant lateral movement. However, the vulnerability is highly likely to be usable in combination with other weaknesses to achieve a higher impact.
- **Low** – Exploitation of the vulnerability would not produce valuable gains for an attacker on its own, however it may be useful in combination with more impactful findings.
- **None** – There is no impact. This is typically assigned to an informational finding.
- **Undetermined** – There is potential for an impact however it cannot be proven currently e.g. a vulnerable feature or configuration option that is currently disabled but may end up inadvertently enabled in the future.

Likelihood:

- **High** – Attackers are highly likely to identify and exploit this vulnerability with trivial tools and knowledge.
- **Medium** – Attackers would be able to exploit this vulnerability under certain conditions or in combination with other findings only, or the vulnerability is technically not trivial to exploit. This would also apply in the case where there are mitigating circumstances/security controls that make exploitation more difficult.
- **Low** – The target is not easily reachable or exploitable for any reason e.g. complex to exploit, target only reachable by specific users from a specific location, public CVE exists for the service however there is no proof of concept for exploitation available etc.
- **None** – There is no likelihood of exploitation. This is typically assigned to an informational finding.
- **Undetermined** – There is an impact (or potential for impact), however it was not possible to demonstrate a direct path to exploitation in the current context of the finding.

Retest Status:

- **Fixed** – Confirmed as completely fixed. The fix did not introduce a new attack surface.
- **Partially Fixed** – The fix is partially effective but still leaves an attack surface exposed.

- **Mitigated** – No fix was applied however the attack surface has been removed by mitigation e.g. isolating a vulnerable service. There may still be potential for the attack surface to re-appear if the mitigation is reversed inadvertently.
- **Not Fixed** – An attempt was made to remediate the finding but was not effective. Attack surface still exists even if access to it has changed.
- **Risk Accepted** – The remediation team has decided that the finding will not be fixed going forward and provided reasoning.